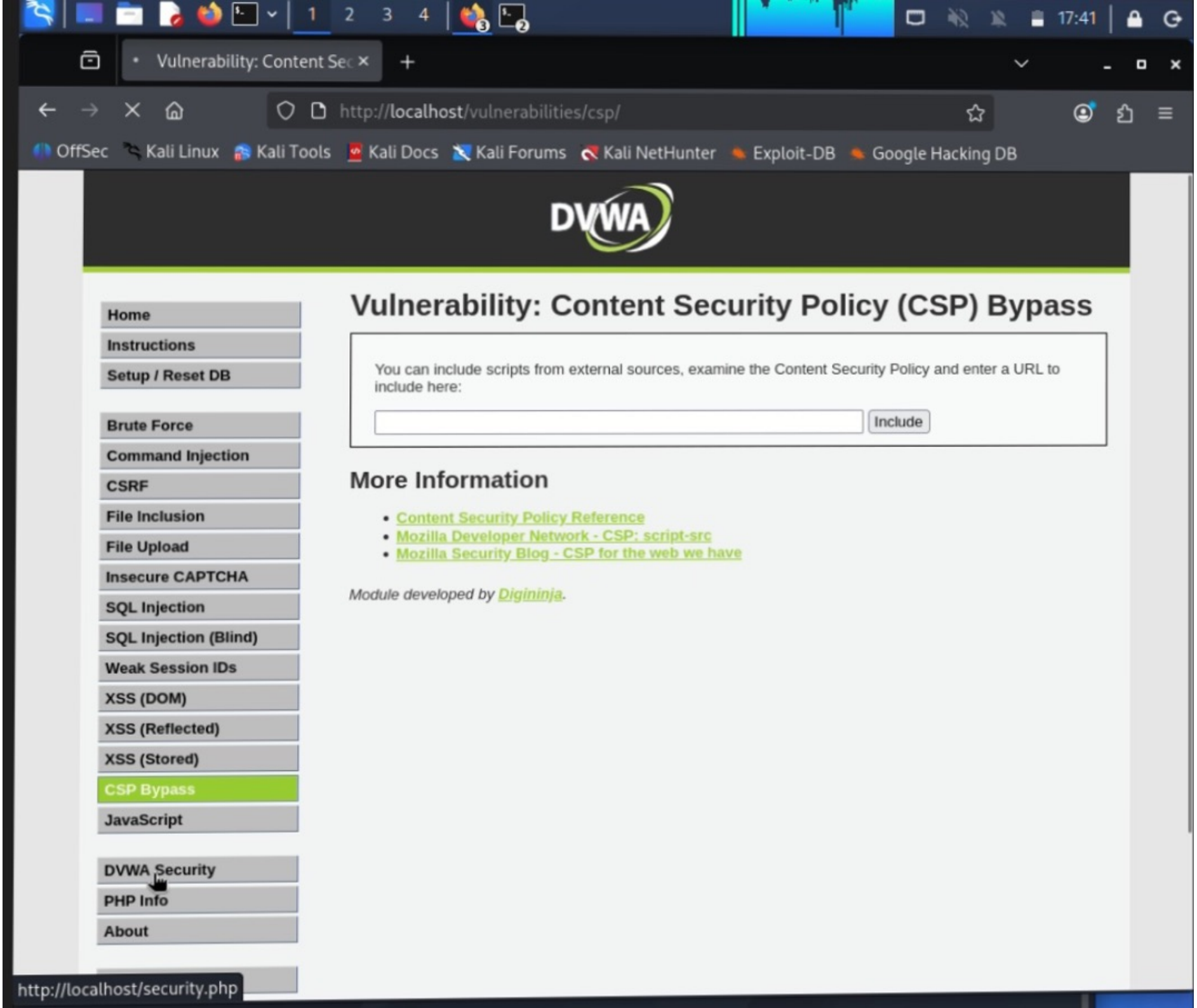
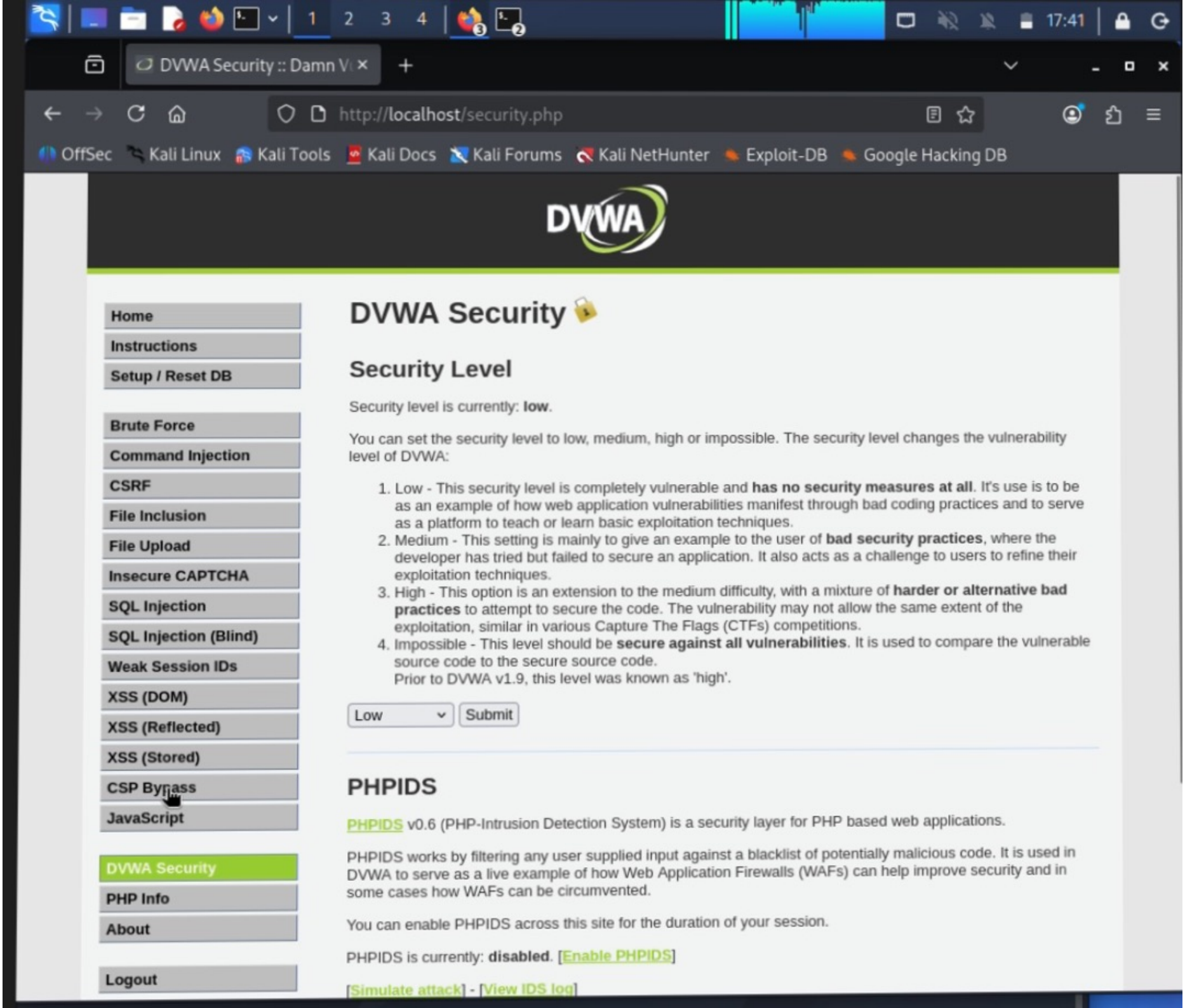
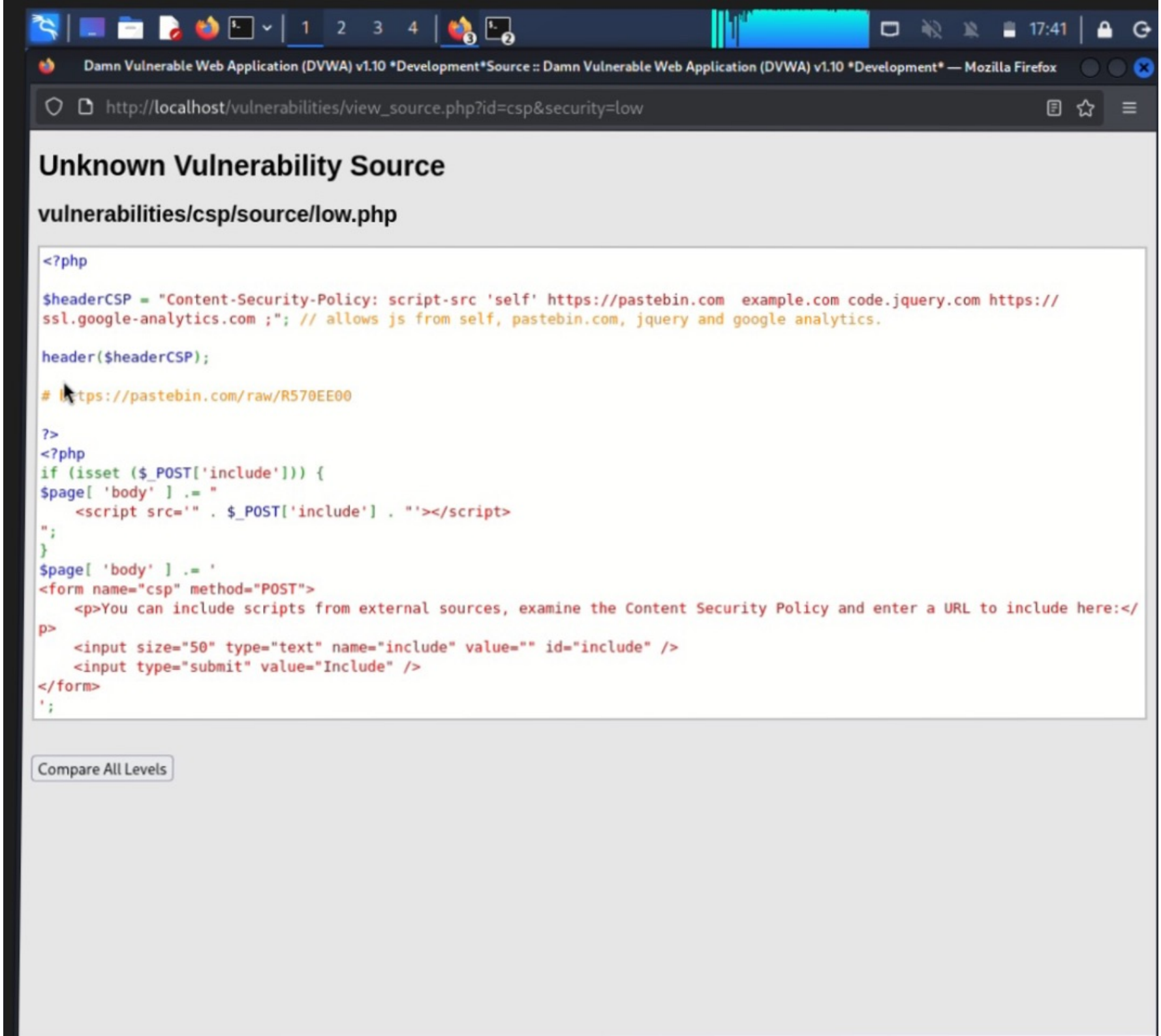
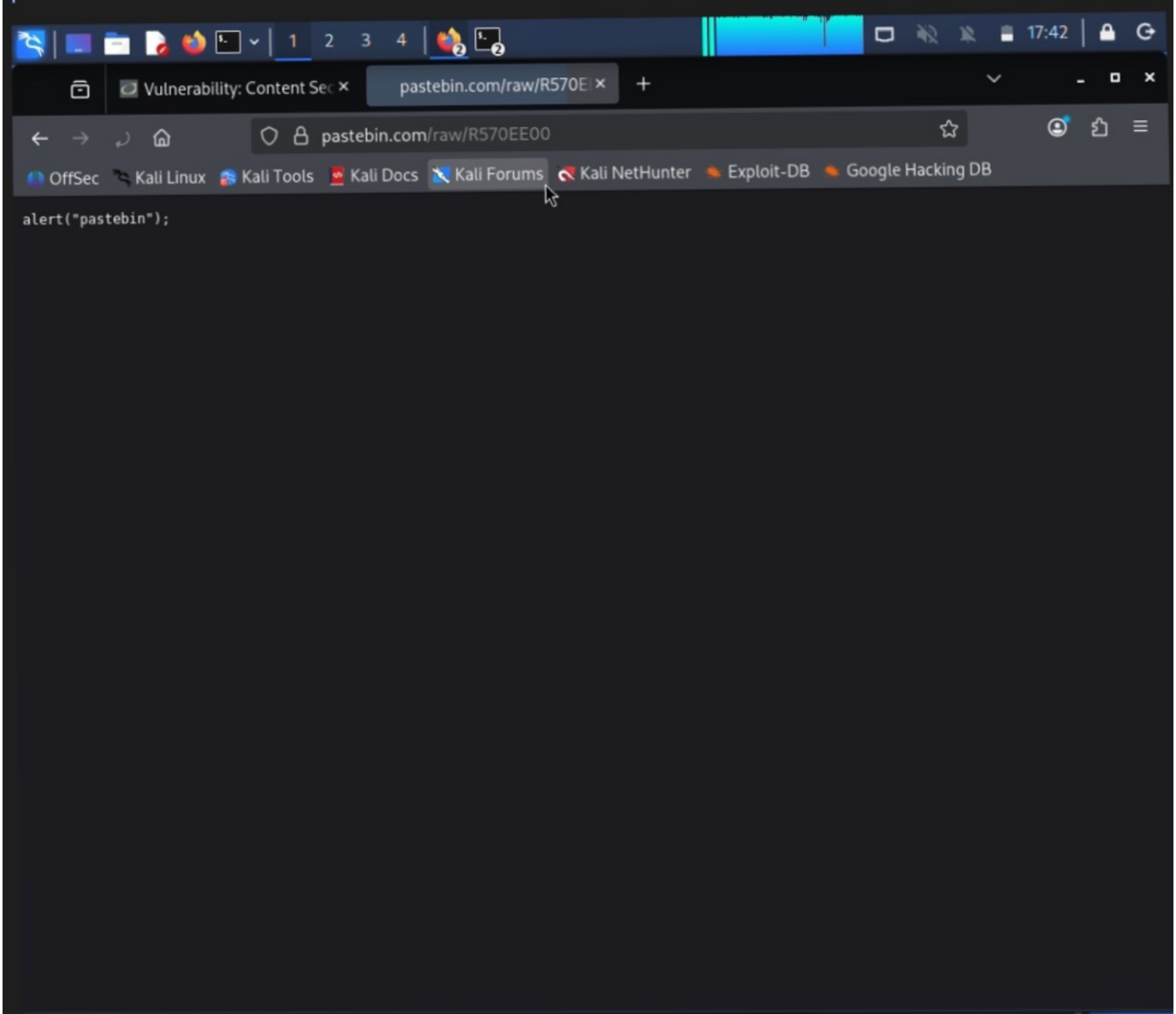
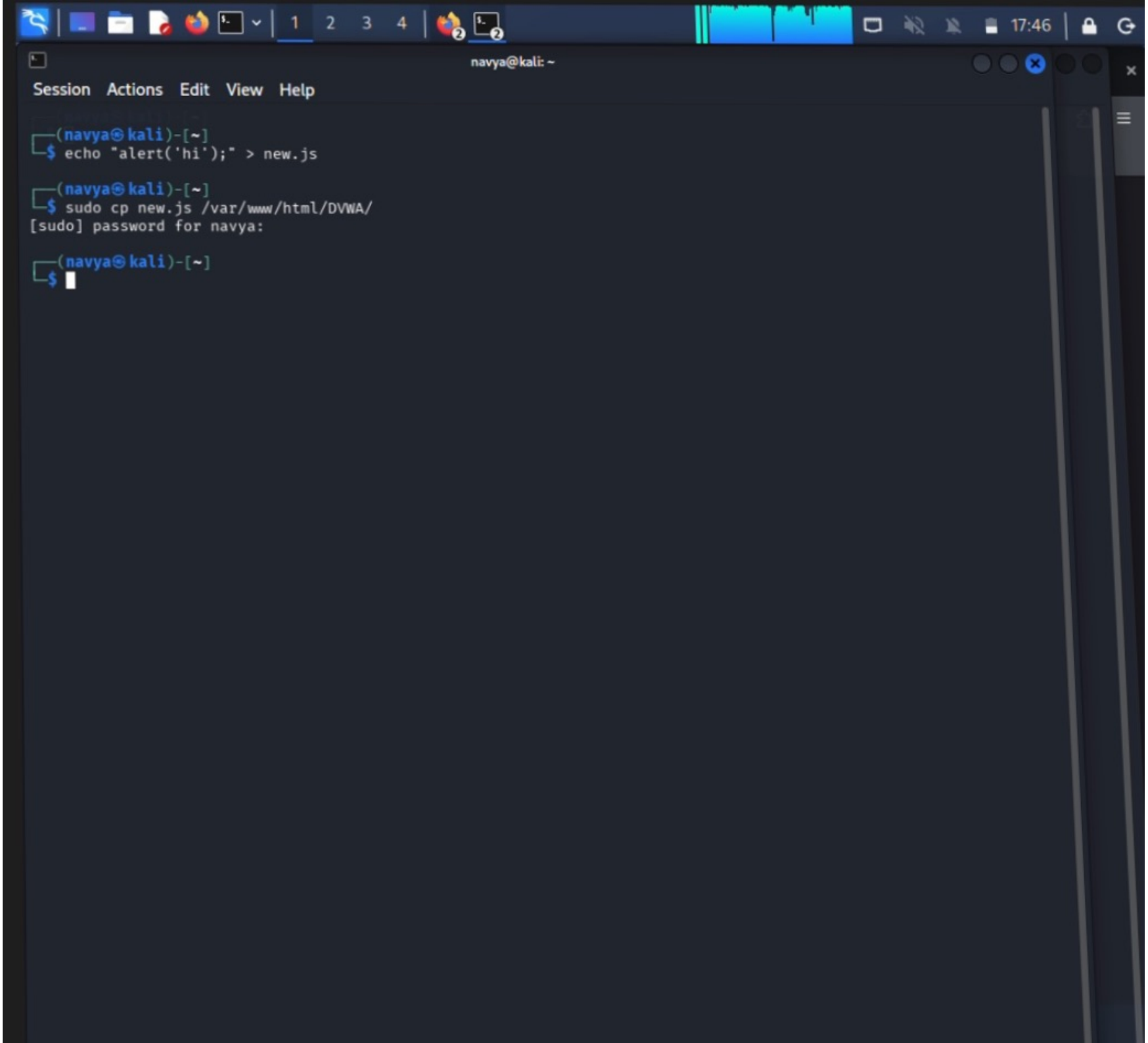
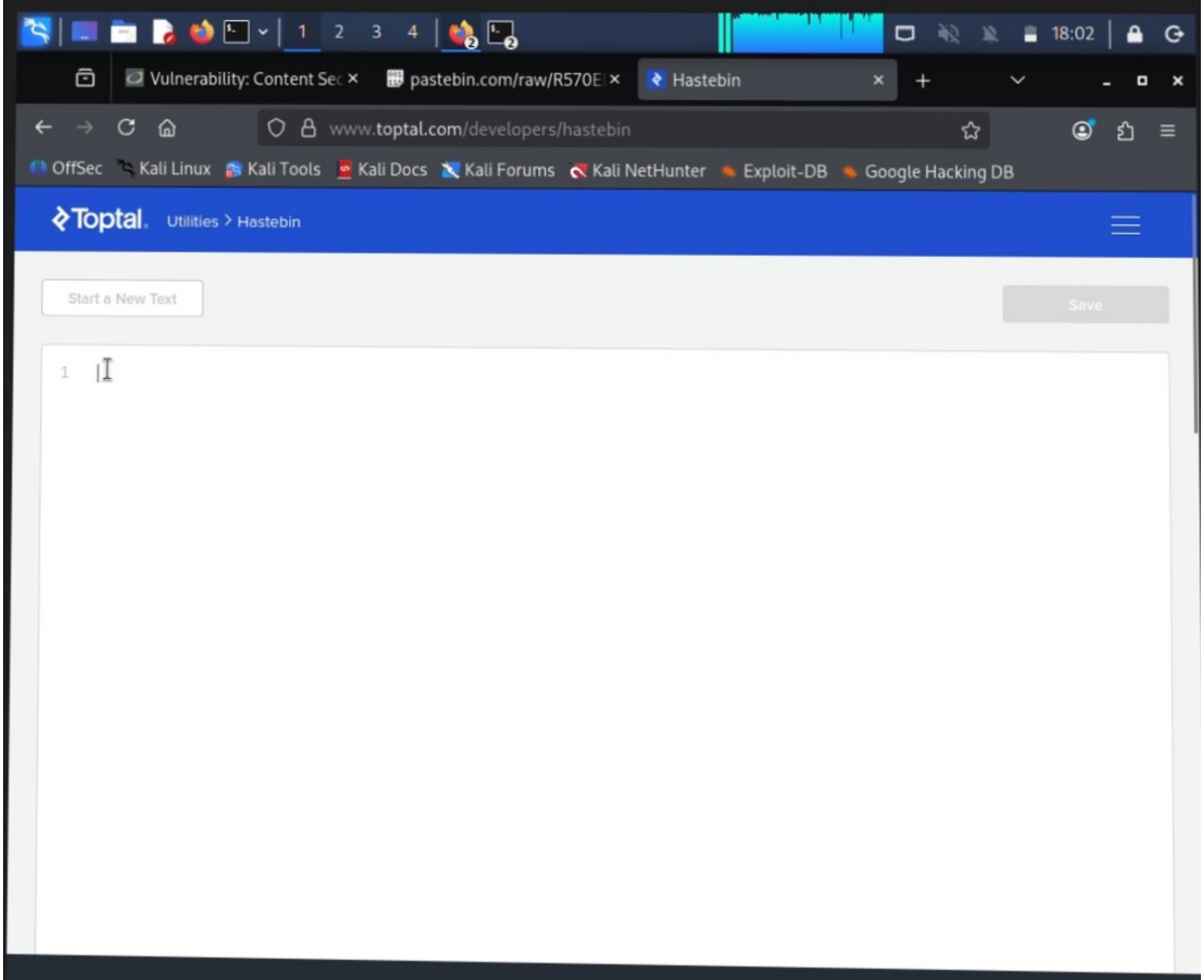

Vulnerability: Content Sec
http://localhost/vulnerabilities/csp/
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Vulnerability: Content Security Policy (CSP) Bypass
You can include scripts from external sources, examine the Content Security Policy and enter a URL to include here:
Include
More Information
Content Security Policy Reference
Mozilla Developer Network - CSP: script-src
Mozilla Security Blog - CSP for the web we have
Module developed by Digininja.
http://localhost/security.php

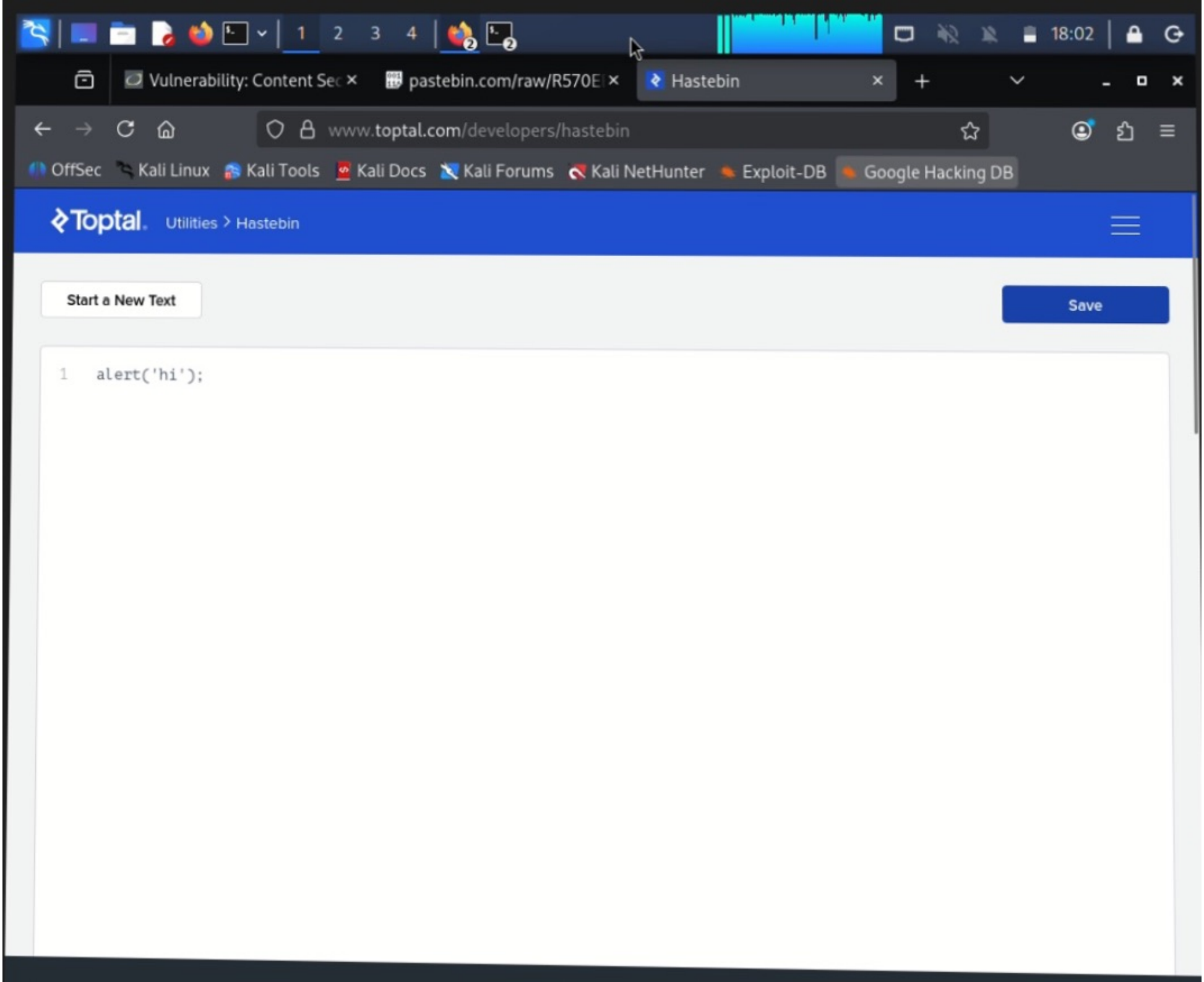

DVWA Security :: Damn V
http://localhost/security.php
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout
DVWA Security
Security Level
Security level is currently: low.
You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:
1. Low - This security level is completely vulnerable and has no security measures at all. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of bad security practices, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of harder or alternative bad practices to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be secure against all vulnerabilities. It is used to compare the vulnerable source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.
Low
Submit
PHPIDS
PHPIDS v0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.
PHPIDS works by filtering any user supplied input against a blacklist of potentially malicious code. It is used in DVWA to serve as a live example of how Web Application Firewalls (WAFs) can help improve security and in some cases how WAFs can be circumvented.
You can enable PHPIDS across this site for the duration of your session.
PHPIDS is currently: disabled. [Enable PHPIDS]
[Simulate attack] - [View IDS log]

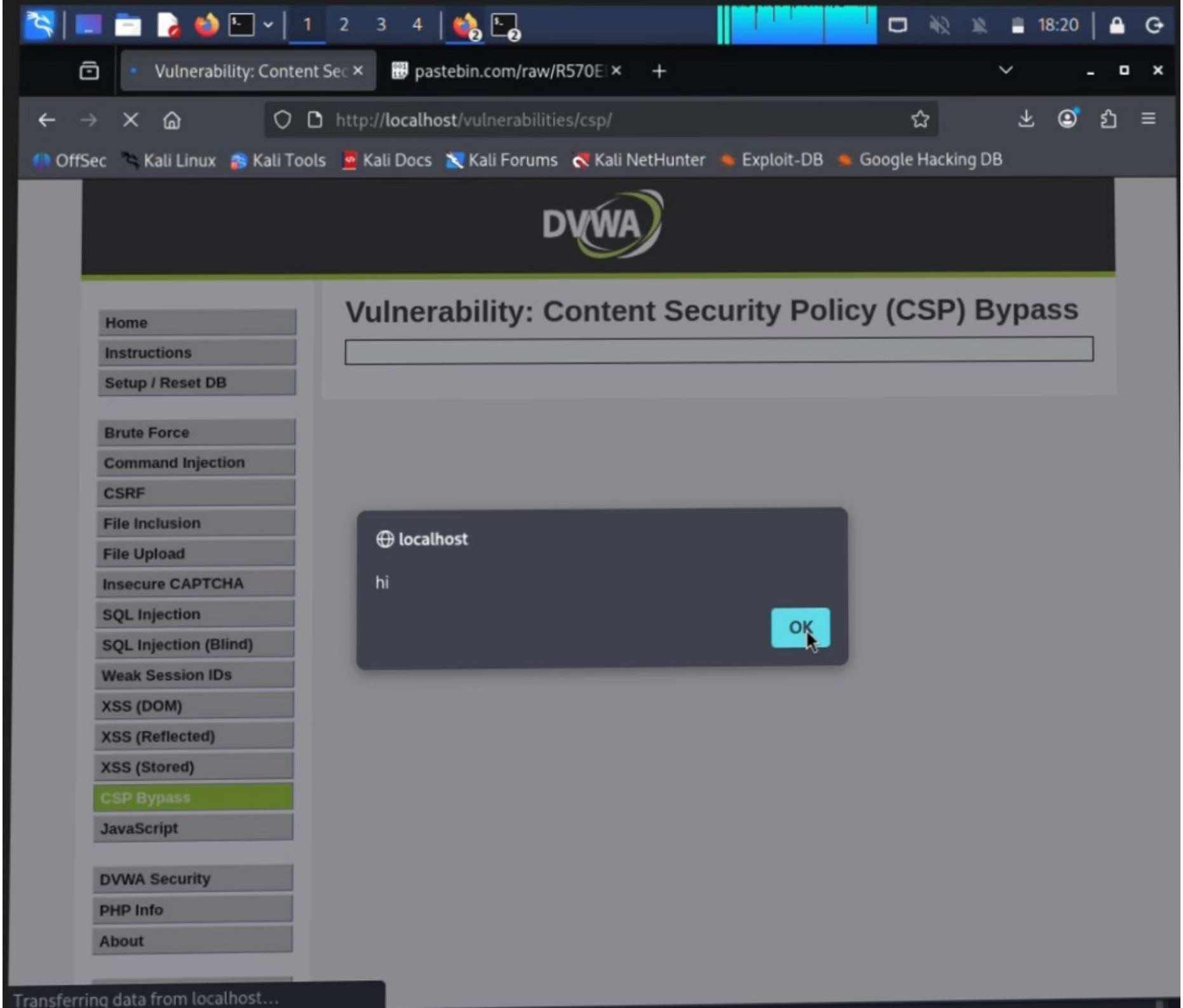

1 2 3 4
17:41
Damn Vulnerable Web Application (DVWA) v1.10 *Development*Source :: Damn Vulnerable Web Application (DVWA) v1.10 *Development* — Mozilla Firefox
http://localhost/vulnerabilities/view_source.php?id=csp&security=low
Unknown Vulnerability Source
vulnerabilities/csp/source/low.php
<?php
$headerCSP = "Content-Security-Policy: script-src 'self' https://pastebin.com example.com code.jquery.com https://ssl.google-analytics.com ;"; // allows js from self, pastebin.com, jquery and google analytics.
header($headerCSP);
# https://pastebin.com/raw/R570EE00
?>
<?php
if (isset ($_POST['include'])) {
$page['body'] .= "
<script src='" . $_POST['include'] . "'></script>
";
}
$page['body'] .= '
<form name="csp" method="POST">
You can include scripts from external sources, examine the Content Security Policy and enter a URL to include here:
<input size="50" type="text" name="include" value="" id="include" />
<input type="submit" value="Include" />
</form>
';
Compare All Levels

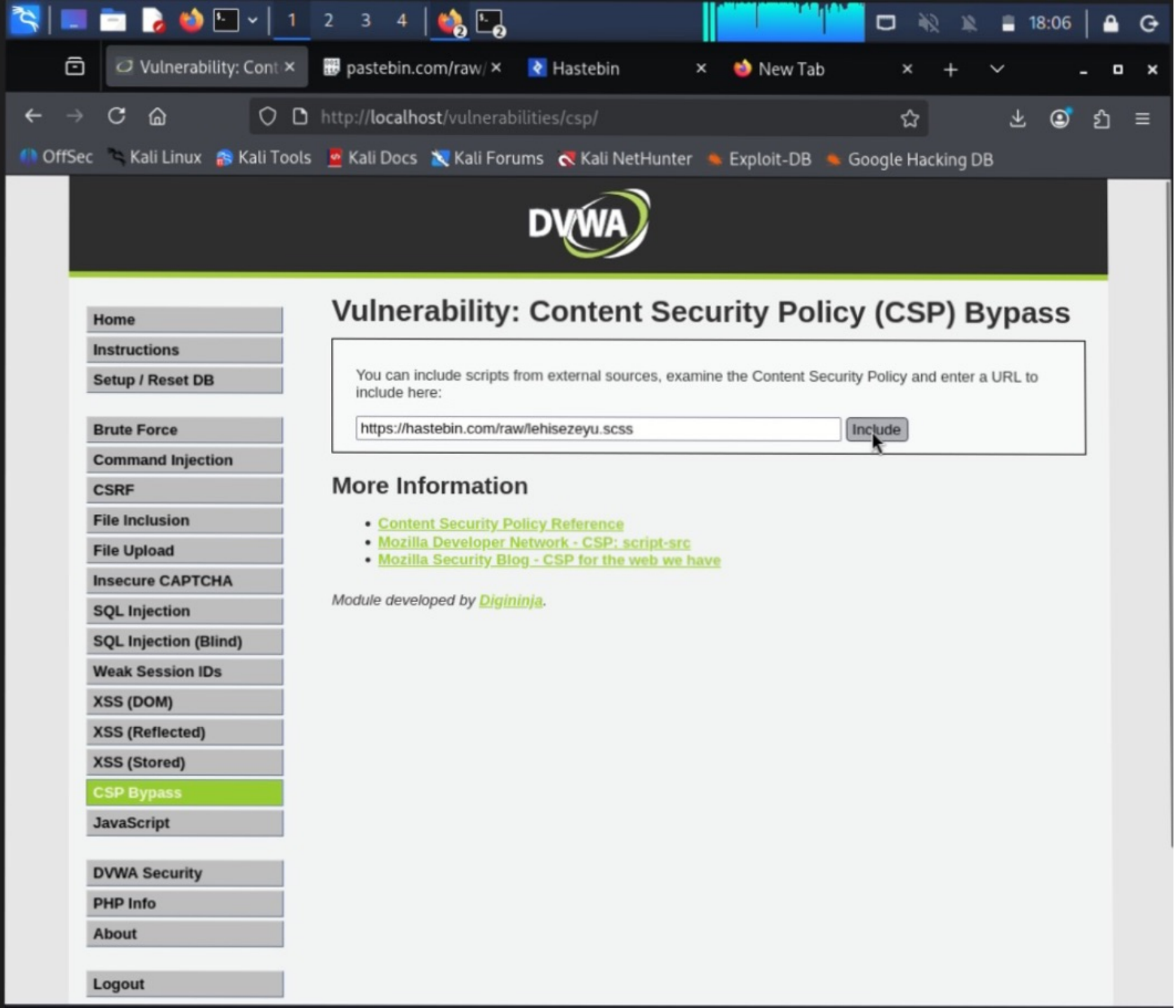

1 2 3 4
17:42
Vulnerability: Content Sec
pastebin.com/raw/R570E
pastebin.com/raw/R570EE00
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
alert("pastebin");


1 2 3 4
17:46
navya@kali: ~
Session Actions Edit View Help
┌──(navya㉿kali)-[~]
└─$ echo "alert('hi');" > new.js
┌──(navya㉿kali)-[~]
└─$ sudo cp new.js /var/www/html/DVWA/
[sudo] password for navya:
┌──(navya㉿kali)-[~]
└─$


1 2 3 4
18:02
Vulnerability: Content Sec
pastebin.com/raw/R570E
Hastebin
www.toptal.com/developers/hastebin
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
Toptal.
Utilities > Hastebin
Start a New Text
Save
1


18:02
Vulnerability: Content Sec
pastebin.com/raw/R570E
Hastebin
www.toptal.com/developers/hastebin
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
Toptal.
Utilities > Hastebin
Start a New Text
Save
1 alert('hi');


1 2 3 4
18:20
Vulnerability: Content Sec
pastebin.com/raw/R570E
http://localhost/vulnerabilities/csp/
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
DVWA
Vulnerability: Content Security Policy (CSP) Bypass
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
localhost
hi
OK
Transferring data from localhost...


Vulnerability: Cont
pastebin.com/raw/
Hastebin
New Tab
http://localhost/vulnerabilities/csp/
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout
Vulnerability: Content Security Policy (CSP) Bypass
You can include scripts from external sources, examine the Content Security Policy and enter a URL to include here:
https://hastebin.com/raw/lehisezeyu.scss
Include
More Information
Content Security Policy Reference
Mozilla Developer Network - CSP: script-src
Mozilla Security Blog - CSP for the web we have
Module developed by Digininja.


20:43
DVWA Security :: Damn V
pastebin.com/raw/R570E
http://localhost/security.php
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
DVWA Security
Security Level
Security level is currently: low.
You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:
1. Low - This security level is completely vulnerable and has no security measures at all. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of bad security practices, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of harder or alternative bad practices to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be secure against all vulnerabilities. It is used to compare the vulnerable source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.
Medium
Submit
PHPIDS
PHPIDS v0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.
PHPIDS works by filtering any user supplied input against a blacklist of potentially malicious code. It is used in DVWA to serve as a live example of how Web Application Firewalls (WAFs) can help improve security and in some cases how WAFs can be circumvented.
You can enable PHPIDS across this site for the duration of your session.
PHPIDS is currently: disabled. [Enable PHPIDS]

Damn Vulnerable Web Application (DVWA) v1.10 *Development*Source :: Damn Vulnerable Web Application (DVWA) v1.10 *Development* — Mozilla Firefox

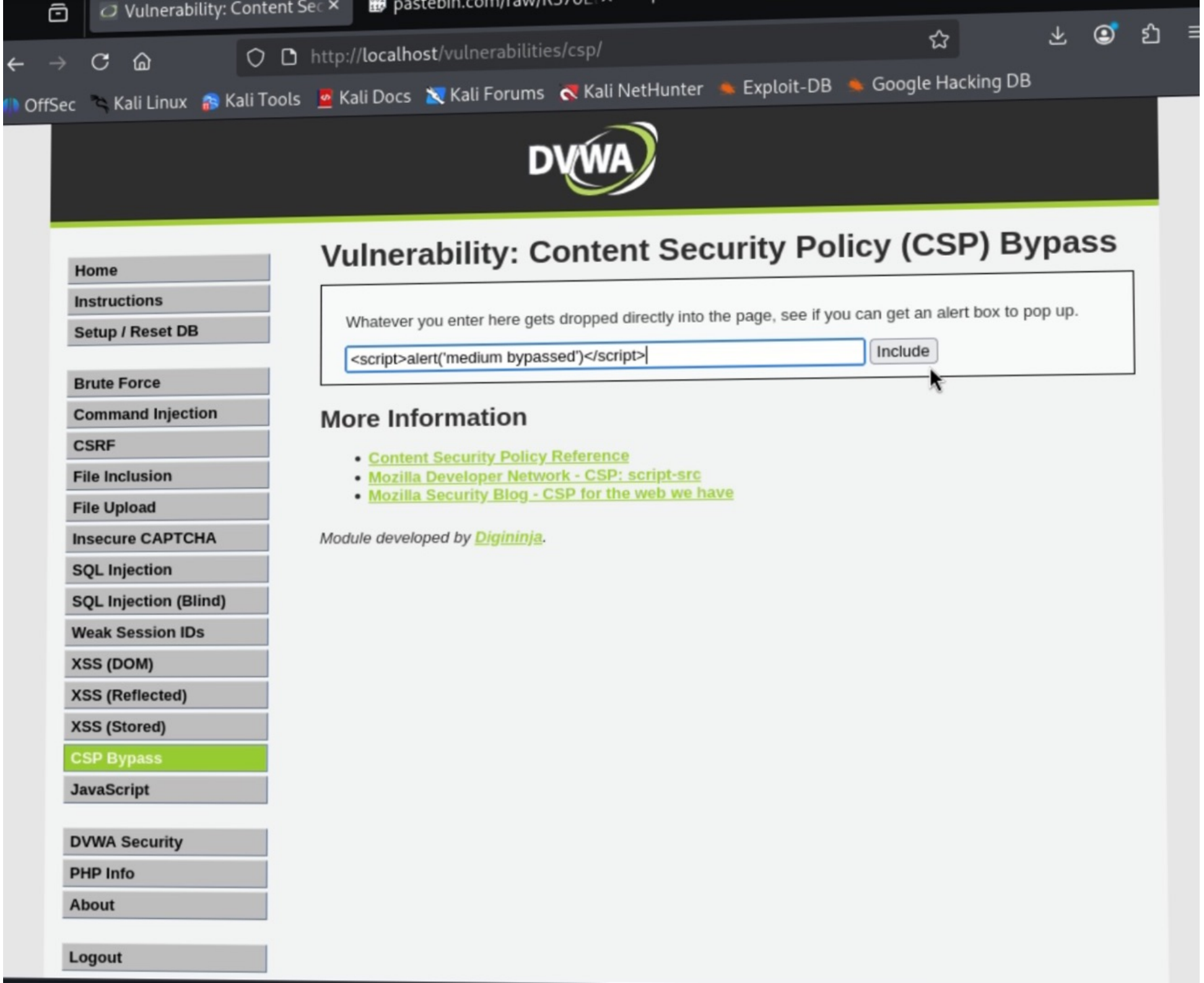
http://localhost/vulnerabilities/view_source.php?id=csp&security=medium

Unknown Vulnerability Source

vulnerabilities/csp/source/medium.php

```
<?php

$headerCSP = "Content-Security-Policy: script-src 'self' 'unsafe-inline' 'nonce-TmV2ZXIgZ29pbmcgdG8gZ2l2ZSB5b3UgdXA=';";

header($headerCSP);

// Disable XSS protections so that inline alert boxes will work
header ("X-XSS-Protection: 0");

# <script nonce="TmV2ZXIgZ29pbmcgdG8gZ2l2ZSB5b3UgdXA=">alert(1)</script>

?>
<?php
if (isset ($_POST['include'])) {
$page[ 'body' ] .= "
    " . $_POST['include'] . "
";
}
$page[ 'body' ] .= '
<form name="csp" method="POST">
    <p>Whatever you enter here gets dropped directly into the page, see if you can get an alert box to pop up.</p>
    <input size="50" type="text" name="include" value="" id="include" />
    <input type="submit" value="Include" />
</form>
';
```

Compare All Levels


Vulnerability: Content Sec
http://localhost/vulnerabilities/csp/
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout
Vulnerability: Content Security Policy (CSP) Bypass
Whatever you enter here gets dropped directly into the page, see if you can get an alert box to pop up.
<script>alert('medium bypassed')</script>
Include
More Information
Content Security Policy Reference
Mozilla Developer Network - CSP: script-src
Mozilla Security Blog - CSP for the web we have
Module developed by Digininja.

- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript

- DVWA Security
- PHP Info
- About

- Logout

Vulnerability: Content Security Policy (CSP) Bypass

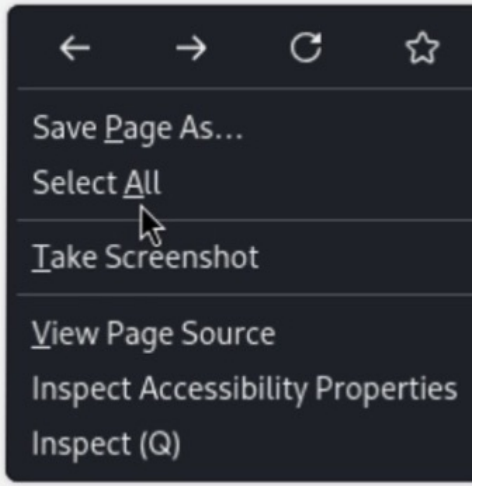
Whatever you enter here gets dropped directly into the page, see if you can get an alert box to pop up.

<script nonce="TmV2ZXIgdG9wYm9uYm9u">alert('medium')</script> Include

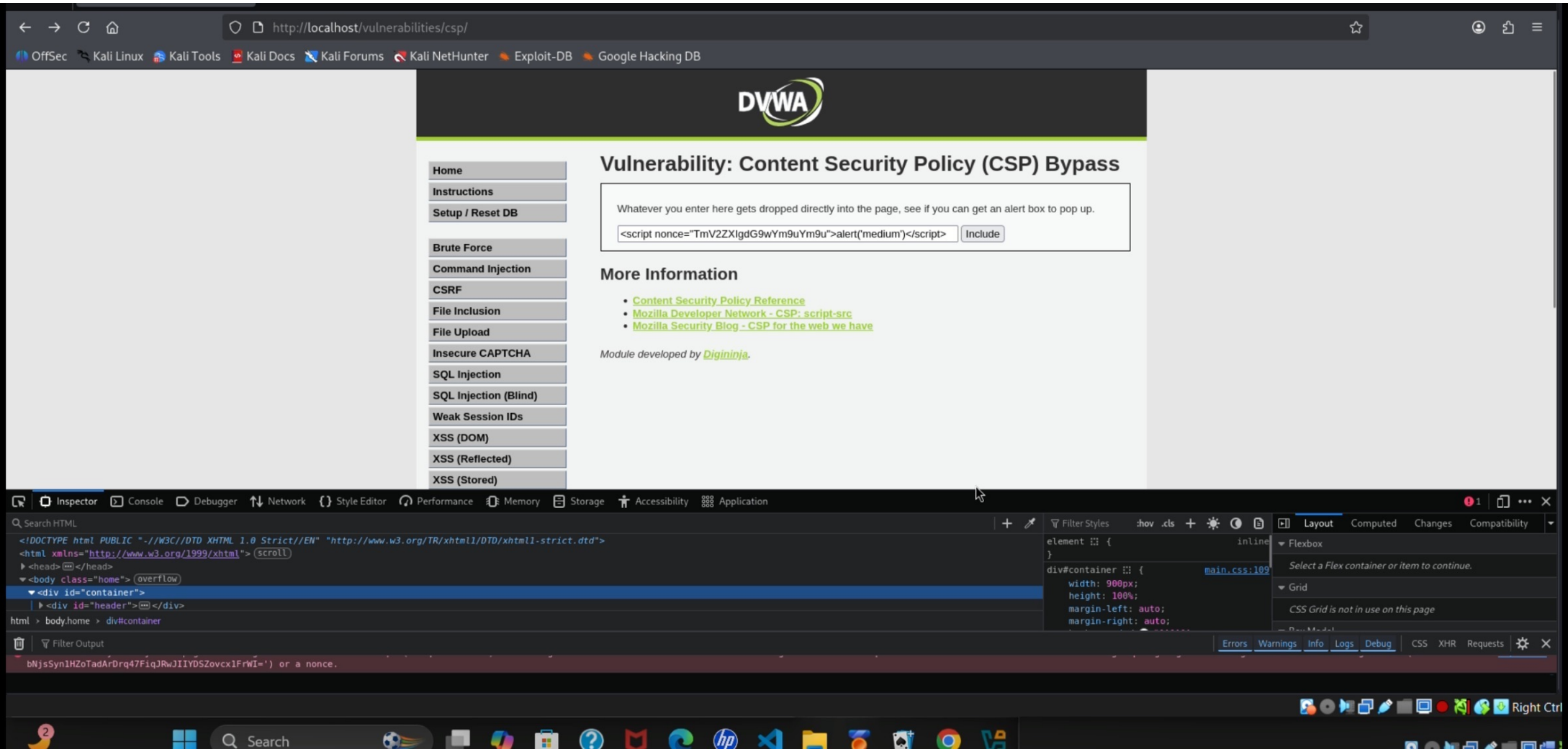
More Information

- Content Security Policy Reference
- Mozilla Developer Network - CSP: script-src
- Mozilla Security Blog - CSP for the web we have

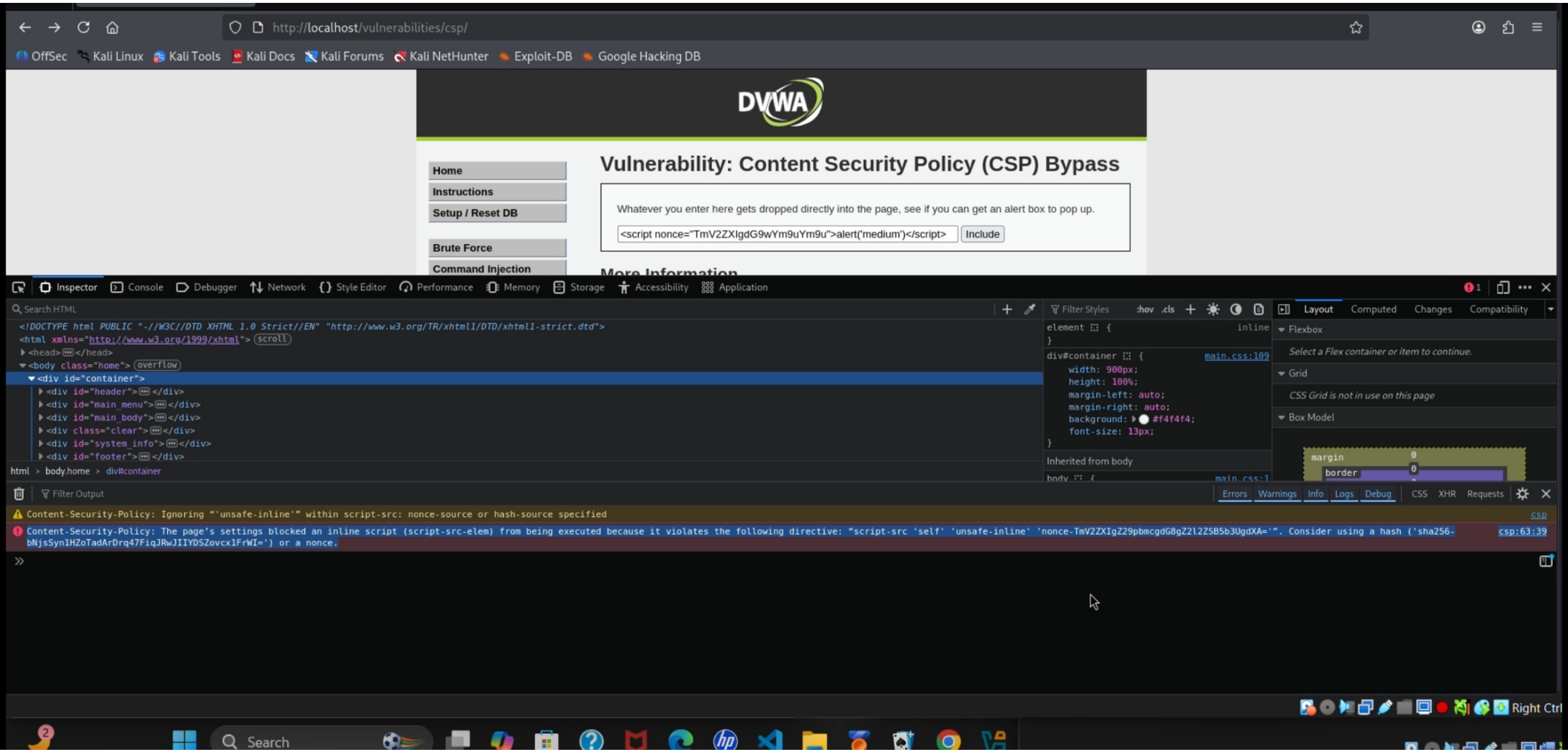
Module developed by Digininja.



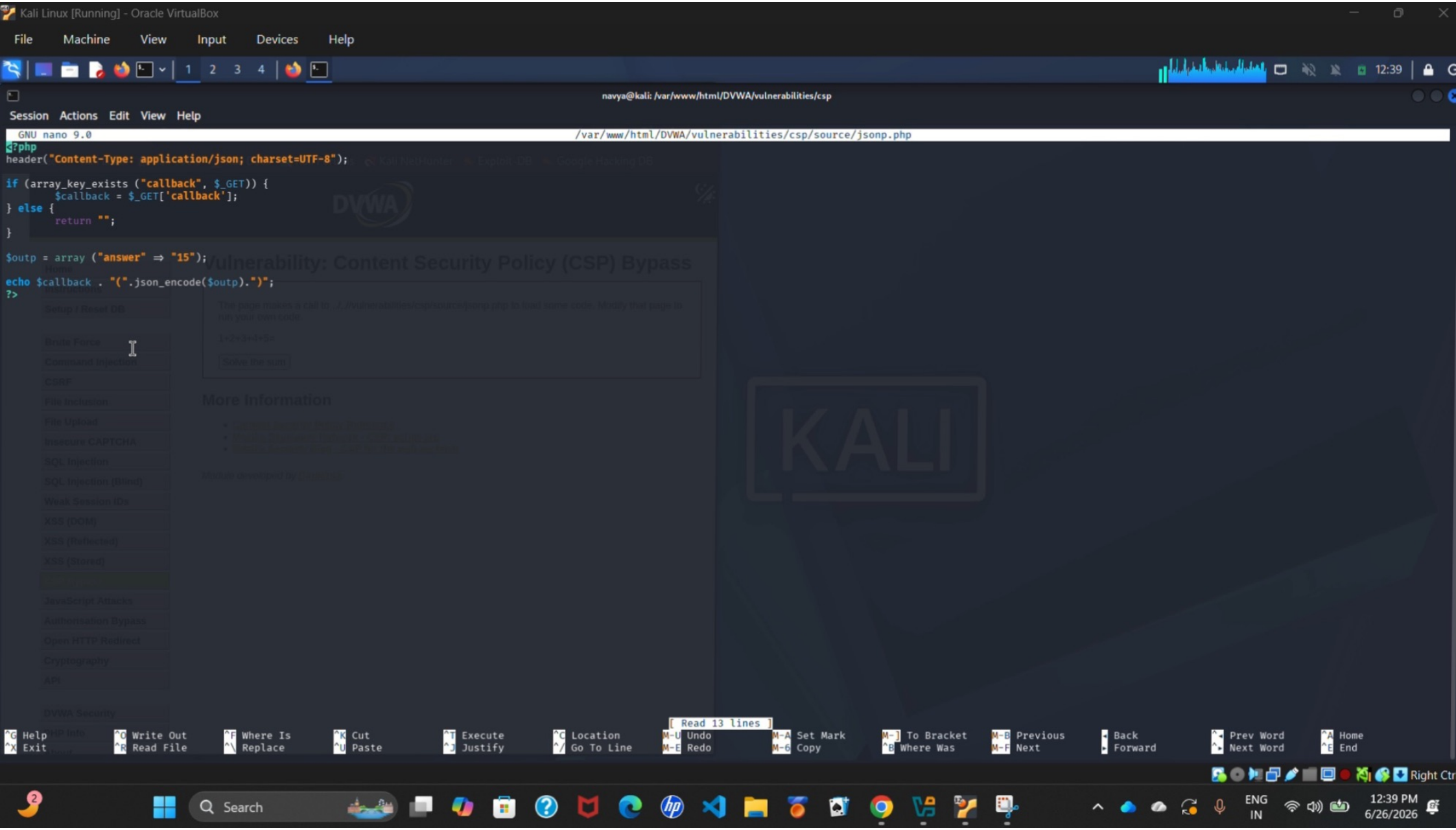
Username: admin

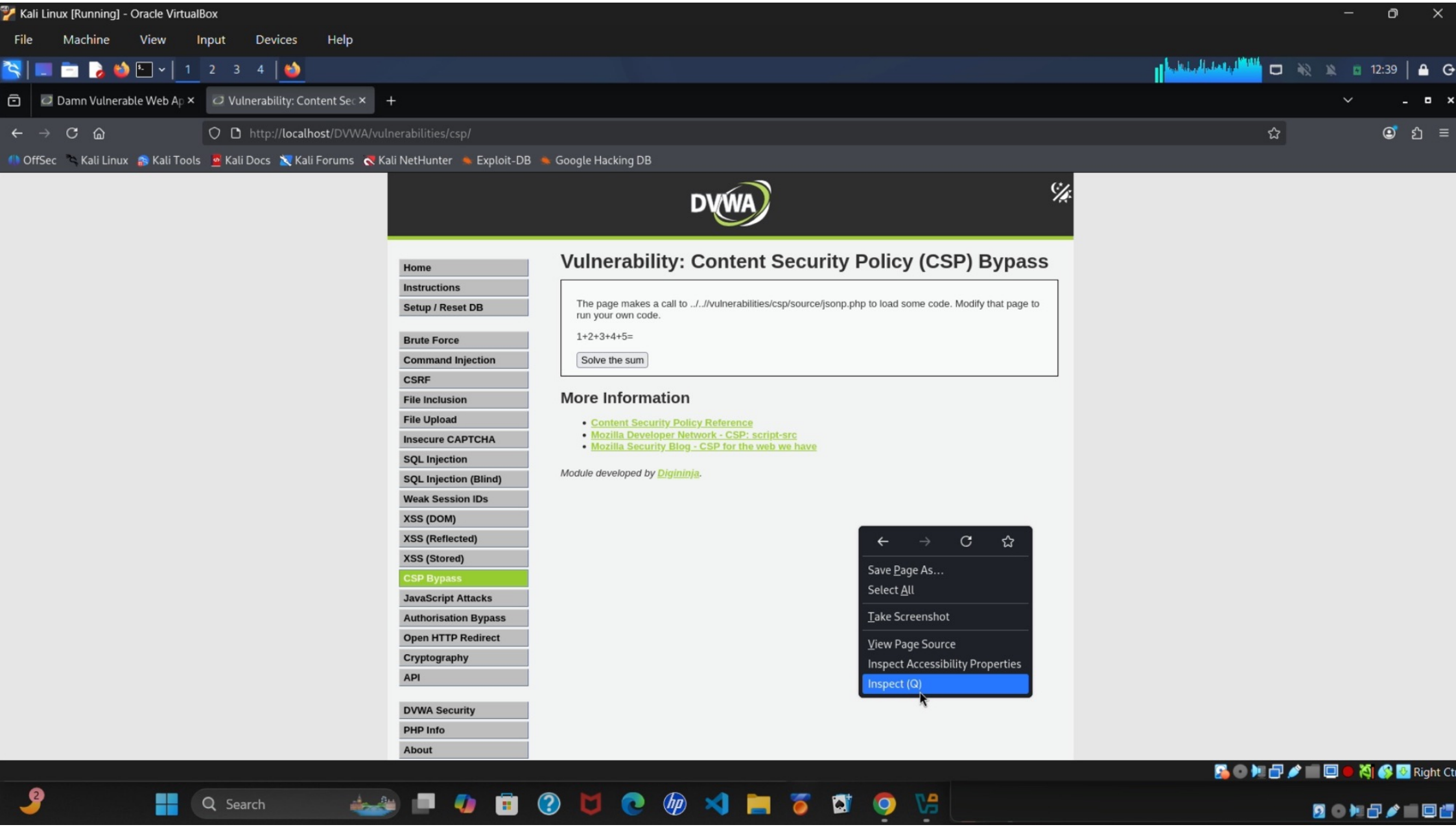

http://localhost/vulnerabilities/csp/
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
Vulnerability: Content Security Policy (CSP) Bypass
Whatever you enter here gets dropped directly into the page, see if you can get an alert box to pop up.
<script nonce="TmV2ZXIgdG9wYm9uYm9u">alert('medium')</script>
Include
More Information
Content Security Policy Reference
Mozilla Developer Network - CSP: script-src
Mozilla Security Blog - CSP for the web we have
Module developed by Digininja.
Inspector
Console
Debugger
Network
Style Editor
Performance
Memory
Storage
Accessibility
Application
Search HTML
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
<body class="home">

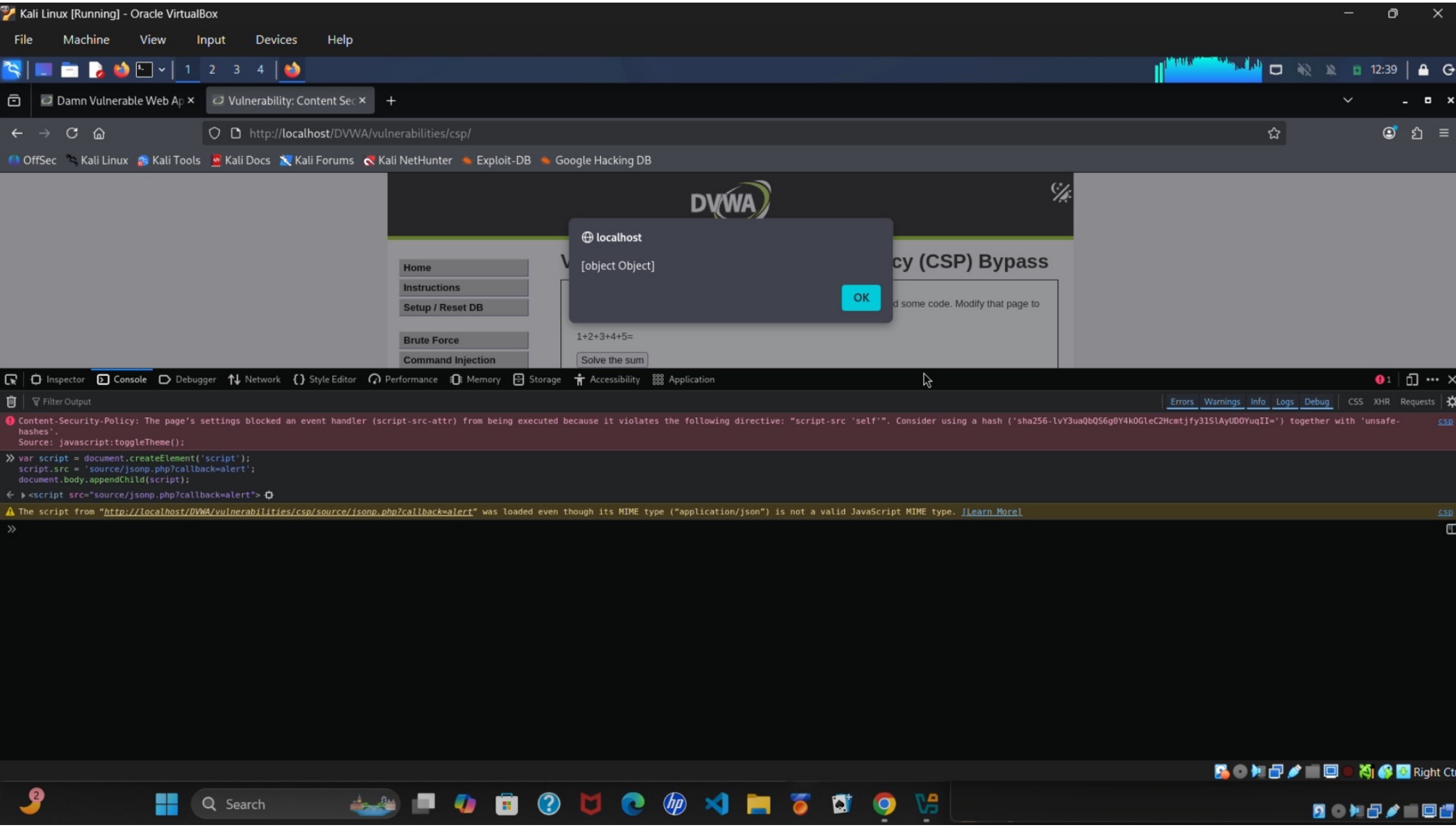
html › body.home › div#container
Filter Styles
element
div#container
main.css:109
width: 900px;
height: 100%;
margin-left: auto;
margin-right: auto;
Layout
Computed
Changes
Compatibility
Flexbox
Select a Flex container or item to continue.
Grid
CSS Grid is not in use on this page
Filter Output
Errors
Warnings
Info
Logs
Debug
CSS
XHR
Requests
bNjsSyn1HZoTadArDrq47FiqJRwJIIYDSZovcx1FrWI=') or a nonce.
Search
Right Ctrl

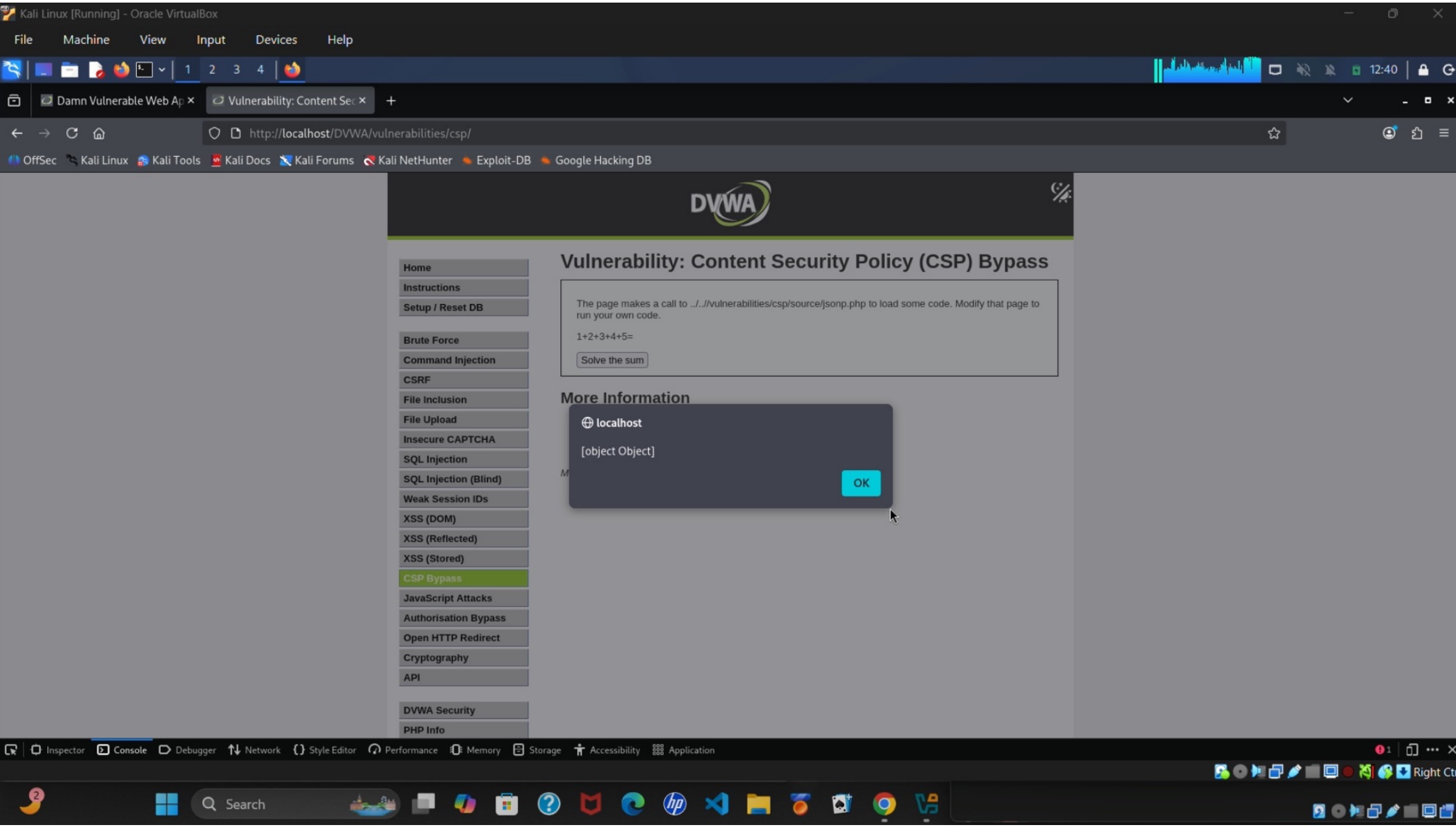

http://localhost/vulnerabilities/csp/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
Vulnerability: Content Security Policy (CSP) Bypass
Whatever you enter here gets dropped directly into the page, see if you can get an alert box to pop up.
<script nonce="TmV2ZXIgdG9wYm9uYm9u">alert('medium')</script>
Include
More Information
Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head></head>
<body class="home">

html › body.home › div#container
element { inline }
div#container { main.css:109
width: 900px;
height: 100%;
margin-left: auto;
margin-right: auto;
background: #f4f4f4;
font-size: 13px;
}
Inherited from body
Layout Computed Changes Compatibility
Flexbox
Select a Flex container or item to continue.
Grid
CSS Grid is not in use on this page
Box Model
margin
border
Content-Security-Policy: Ignoring "'unsafe-inline'" within script-src: nonce-source or hash-source specified
Content-Security-Policy: The page's settings blocked an inline script (script-src-elem) from being executed because it violates the following directive: "script-src 'self' 'unsafe-inline' 'nonce-TmV2ZXIgZ29pbmcgdG8gZ2l2ZSB5b3UgdXA='". Consider using a hash ('sha256-bNjsSyn1HZoTadArDrq47FiqJRwJIIYDSZovcx1FrWI=') or a nonce.
csp:63:39
Right Ctrl
Search


Kali Linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help
navya@kali: /var/www/html/DVWA/vulnerabilities/csp
Session Actions Edit View Help
GNU nano 9.0 /var/www/html/DVWA/vulnerabilities/csp/source/jsonp.php
<?php
header("Content-Type: application/json; charset=UTF-8");
if (array_key_exists ("callback", $_GET)) {
$callback = $_GET['callback'];
} else {
return "";
}
$outp = array ("answer" => "15");
echo $callback . "(".json_encode($outp).")";
?>
[Read 13 lines]
^G Help ^O Write Out ^F Where Is ^K Cut ^T Execute ^C Location M-U Undo M-A Set Mark M-] To Bracket M-B Previous ^◂ Back ^◂ Prev Word ^A Home
^X Exit ^R Read File ^\ Replace ^U Paste ^J Justify ^/ Go To Line M-E Redo M-6 Copy ^B Where Was M-F Next ^▸ Forward ^▸ Next Word ^E End
Vulnerability: Content Security Policy (CSP) Bypass
More Information
Search
ENG IN
12:39 PM 6/26/2026


Kali Linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Damn Vulnerable Web Ap
Vulnerability: Content Sec
http://localhost/DVWA/vulnerabilities/csp/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Authorisation Bypass
Open HTTP Redirect
Cryptography
API
DVWA Security
PHP Info
About
Vulnerability: Content Security Policy (CSP) Bypass
The page makes a call to ../../vulnerabilities/csp/source/jsonp.php to load some code. Modify that page to run your own code.
1+2+3+4+5=
Solve the sum
More Information
Content Security Policy Reference
Mozilla Developer Network - CSP: script-src
Mozilla Security Blog - CSP for the web we have
Module developed by Digininja.
Save Page As...
Select All
Take Screenshot
View Page Source
Inspect Accessibility Properties
Inspect (Q)
Search


Kali Linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Damn Vulnerable Web Ap
Vulnerability: Content Sec
http://localhost/DVWA/vulnerabilities/csp/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
localhost
[object Object]
OK
cy (CSP) Bypass
d some code. Modify that page to
1+2+3+4+5=
Solve the sum
Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application
Filter Output
Errors Warnings Info Logs Debug CSS XHR Requests
Content-Security-Policy: The page's settings blocked an event handler (script-src-attr) from being executed because it violates the following directive: "script-src 'self'". Consider using a hash ('sha256-lvY3uaQbQS6g0Y4kOGleC2Hcmtjfy31SlAyUDOYuqII=') together with 'unsafe-hashes'.
Source: javascript:toggleTheme();
var script = document.createElement('script');
script.src = 'source/jsonp.php?callback=alert';
document.body.appendChild(script);
<script src="source/jsonp.php?callback=alert">
The script from "http://localhost/DVWA/vulnerabilities/csp/source/jsonp.php?callback=alert" was loaded even though its MIME type ("application/json") is not a valid JavaScript MIME type. [Learn More]
Search
Right Ct


Kali Linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Damn Vulnerable Web Ap
Vulnerability: Content Sec
http://localhost/DVWA/vulnerabilities/csp/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Authorisation Bypass
Open HTTP Redirect
Cryptography
API
DVWA Security
PHP Info
Vulnerability: Content Security Policy (CSP) Bypass
The page makes a call to ../../vulnerabilities/csp/source/jsonp.php to load some code. Modify that page to run your own code.
1+2+3+4+5=
Solve the sum
More Information
localhost
[object Object]
OK
Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application
Search